

**UNIVERSIDAD POLITÉCNICA DE
SAN LUIS POTOSÍ**

CARRERA: Ingeniería en Tecnologías de la Información

MATERIA: CNO IV Seguridad Informática

ACTIVIDAD 04: Una página demasiado convincente

Ojeda Camacho José Carlos / 181629

PROFESOR: Servando López Contreras

Contenido

Objetivo de la actividad.....	3
Descripción del escenario.....	3
Configuración del laboratorio.	3
Topología y entorno virtual	3
Configuración de la red interna.....	4
Esquema de direccionamiento IP estático	4
Preparación de herramientas y plantilla web (SET y HTML).....	4
Evidencias y descripción del funcionamiento.	4
Instalación de Windows 10 Pro	4
Instalación de Kali Linux	5
Configuración de la red interna.....	6
Desarrollo de portal web	7
Configuración de SET.....	7
Intercepción de la información.....	8
Explicación del flujo de captura de información.....	9
Controles de seguridad propuestos.....	10
Indicadores de Phishing	10
Propuesta de controles de seguridad	10
Conclusión.....	12
Referencias	12

Objetivo de la actividad

El objetivo principal de esta práctica es comprender técnicamente la anatomía de un ataque de *Credential Harvesting* mediante el uso de herramientas como el Social-Engineer Toolkit (SET). Al configurar un entorno controlado, puedes observar en tiempo real cómo se engaña a un sistema cliente y se interceptan credenciales en texto plano a través de peticiones HTTP POST, permitiéndote identificar con precisión los indicadores visuales y técnicos de un portal fraudulento.

Este análisis práctico y la posterior documentación de las evidencias obtenidas desarrollan competencias defensivas fundamentales en la ingeniería en tecnologías de la información. Al experimentar la perspectiva ofensiva, obtienes el criterio técnico necesario para evaluar riesgos reales y justificar la implementación de controles de seguridad efectivos, como la autenticación multifactor o el monitoreo de redes, para proteger la infraestructura de cualquier organización.

Descripción del escenario.

El área de seguridad informática de una organización ha recibido varios reportes de empleados que aseguran haber recibido un mensaje relacionado con una supuesta actualización de sus credenciales. El mensaje contiene un enlace que dirige a un portal aparentemente institucional. La página incluye logotipo, campos de usuario y contraseña y un mensaje indicando: “Su sesión ha expirado. Inicie sesión nuevamente para continuar.” A primera vista, nada parece fuera de lo común. Sin embargo, el portal no pertenece a la organización.

El escenario de laboratorio consistió en una red interna y controlada simulada en VirtualBox, compuesta por dos máquinas virtuales aisladas de internet. Por un lado, una máquina atacante con Kali Linux operó como servidor web mediante el Social-Engineer Toolkit (SET) para alojar un portal de inicio de sesión personalizado. Por otro lado, una máquina cliente con Windows 10 simuló a la víctima al navegar hacia el sitio falso, permitiendo comprobar cómo la herramienta interceptó y registró exitosamente solicitudes HTTP POST con credenciales en texto plano para su análisis y documentación.

Configuración del laboratorio.

Para llevar a cabo la práctica de simulación de *Credential Harvesting* de manera segura y controlada, se implementó un entorno virtualizado utilizando Oracle VirtualBox, complementado con la preparación de los componentes lógicos de ataque.

Topología y entorno virtual

El laboratorio consta de dos máquinas virtuales configuradas en un entorno de pruebas cerrado:

- Máquina Atacante (Kali Linux): Sistema operativo base para la ejecución de herramientas de pruebas de penetración y despliegue del servidor malicioso.
- Máquina Víctima (Windows 10): Sistema operativo cliente utilizado para simular la interacción del usuario final ante el escenario de ingeniería social.

Configuración de la red interna

Para garantizar el aislamiento y la conectividad directa entre ambos equipos, se configuró en los ajustes de VirtualBox un adaptador de red de tipo Red interna bajo el mismo identificador (Iabcno4) tanto en la máquina virtual de Kali Linux como en la de Windows 10, permitiendo que los paquetes de red viajen exclusivamente entre los dos nodos virtuales del laboratorio.

Esquema de direccionamiento IP estático

Con el fin de asegurar una comunicación estable y predecible, se estableció de forma manual un esquema de direccionamiento IP estático dentro del mismo segmento de red (192.168.10.x/24):

- Dirección IP de Kali Linux (Atacante): 192.168.10.3 (con máscara de subred 255.255.255.0 o prefijo /24).
- Dirección IP de Windows 10 (Víctima): 192.168.10.2 (con máscara de subred 255.255.255.0).

Preparación de herramientas y plantilla web (SET y HTML)

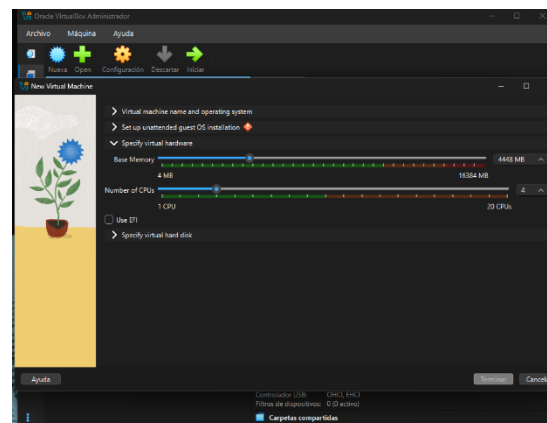
Como parte final de la configuración previa al ejercicio, se prepararon los elementos de software y la interfaz de ataque:

- Social-Engineer Toolkit (SET): Se configuró el uso de esta herramienta en Kali Linux, preparándola para operar mediante su módulo de *Credential Harvester* en el puerto 80, encargado de escuchar y procesar las peticiones web de la red interna.
- Personalización del archivo HTML: Se modificó y estructuró un archivo index.html local para simular un portal de inicio de sesión corporativo legítimo ("AETHEL INNOVATIONS"). Este diseño incluyó elementos visuales de ingeniería social, como mensajes de alerta de sesión expirada y campos definidos para la captura de credenciales ("Mail" y "Password").

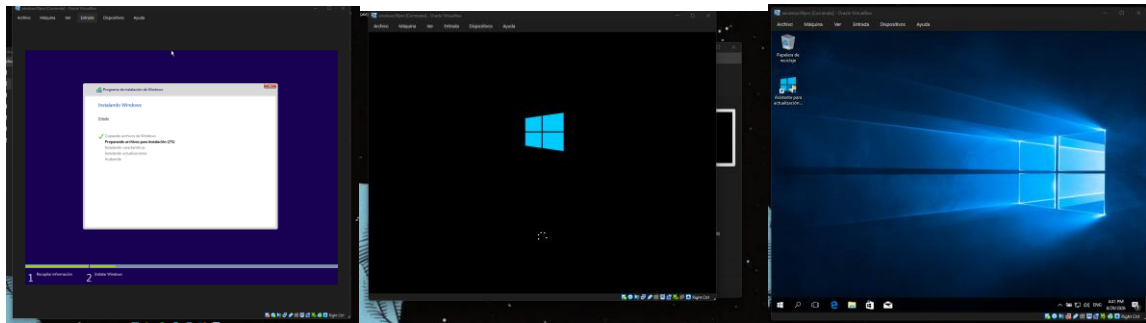
Evidencias y descripción del funcionamiento.

Instalación de Windows 10 Pro

El proceso de instalación de la máquina virtual en VirtualBox comienza configurando el nombre como "Windows 10 Pro", validando la ruta de destino y seleccionando la imagen ISO de Windows 10 Pro (32 bits), junto con los parámetros de la edición y la opción de instalación desatendida. A continuación, se asignan los recursos de hardware virtual configurando 4448 MB de memoria base y 4 CPUs. Finalmente, se establece la creación de un nuevo disco duro virtual en formato VDI (VirtualBox Disk Image) con una capacidad de 8,04 GB para completar la configuración inicial.

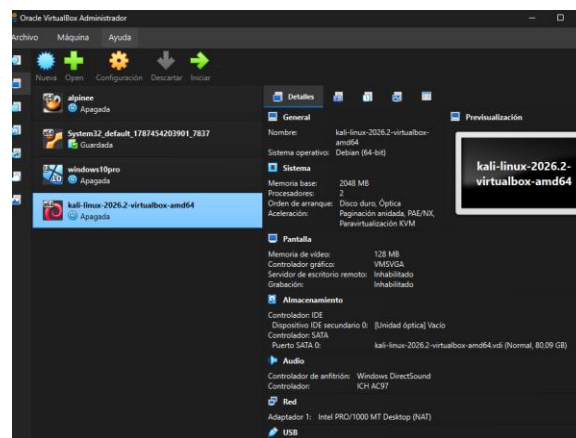


Una vez iniciada la máquina virtual, el sistema operativo procede a una fase de instalación automatizada, pasando por varias pantallas de carga y reinicios automáticos sin necesidad de intervención humana. Al tratarse de una instalación desatendida, el proceso se completa de forma fluida y autónoma, concluyendo con el arranque directo hacia el escritorio completamente configurado de Windows 10 Pro, donde ya son visibles iconos como la Papelera de reciclaje y el asistente para actualizaciones, así como la barra de tareas con el menú de inicio, el explorador de archivos y la hora del sistema.



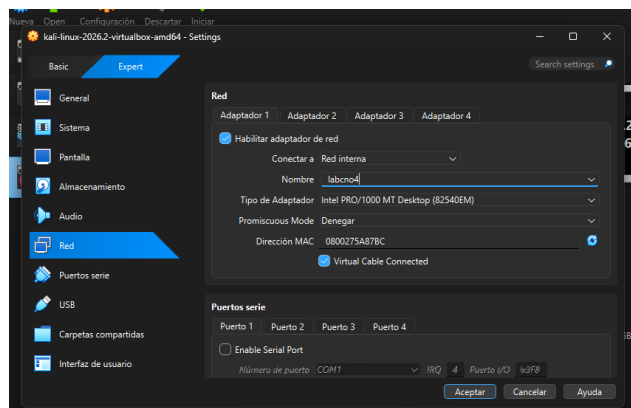
Instalación de Kali Linux

Se descargó el archivo comprimido de la máquina virtual de Kali Linux (kali-linux-2026.2-virtualbox-amd64), el cual se procedió a descomprimir en el equipo para extraer los archivos correspondientes. Una vez realizada esta extracción, se abrió y cargó la máquina virtual directamente en la interfaz del Administrador de Oracle VM VirtualBox, quedando listada y configurada de manera correcta con sus parámetros predefinidos (como su arquitectura de 64 bits, los recursos asignados de memoria RAM y procesador, y su disco virtual) en estado apagada y lista para ser iniciada.



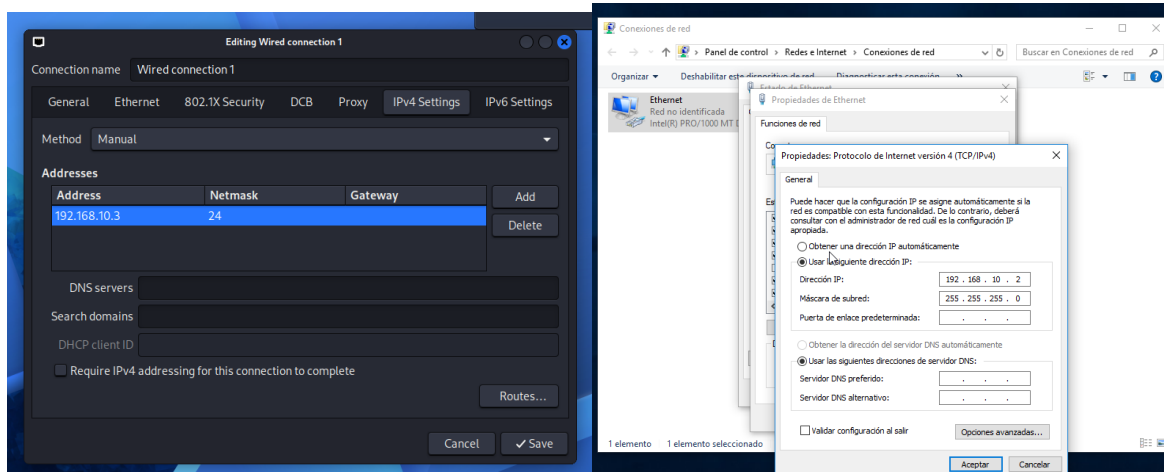
Configuración de la red interna

En la configuración de la máquina virtual de Kali Linux, dentro del apartado de Red, se habilita el adaptador y se configura para conectarse a una **Red interna**, asignándole el nombre "**labcno4**", mientras que en la máquina virtual de Windows 10 se realiza exactamente el mismo procedimiento de red y se le asigna el mismo nombre de red interna para permitir la comunicación aislada entre ambas máquinas, y se da clic en aceptar.



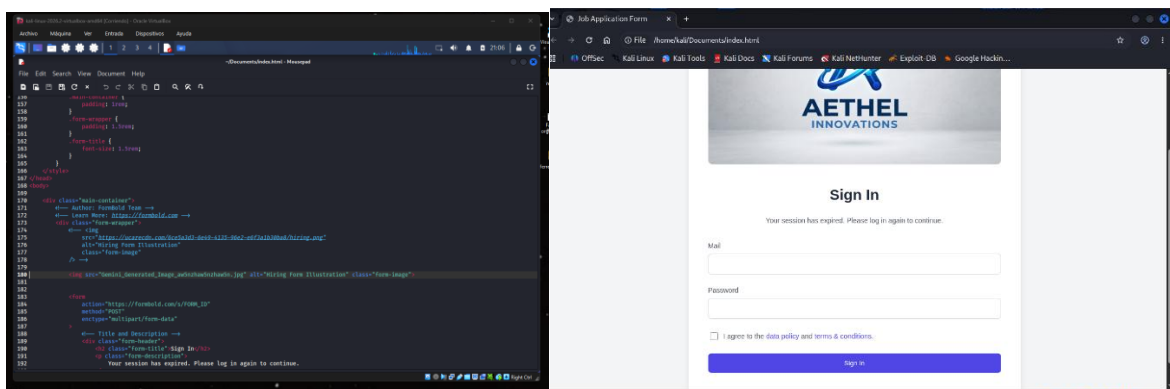
Esto se hace para establecer una red interna aislada y directa entre ambas máquinas virtuales en VirtualBox, permitiendo que se comuniquen exclusivamente entre ellas sin exposición a internet ni a la red física exterior, lo cual es necesario para simular un entorno de laboratorio controlado donde la máquina atacante (Kali Linux) y la víctima (Windows 10) puedan interactuar de forma segura para las pruebas de *Credential Harvesting*.

Para configurar las identidades de ambos equipos en la red interna, en la ventana de propiedades de Protocolo de Internet versión 4 (TCP/IPv4) de Windows 10 se selecciona la opción de usar una dirección IP estática, configurando la dirección 192.168.10.2 y la máscara de subred 255.255.255.0. Paralelamente, en la configuración de conexiones de red de Kali Linux, dentro de la pestaña de IPv4 Settings, se cambia el método a manual y se agrega la dirección IP 192.168.10.3 con máscara 24. Esto se realiza para asignar un direccionamiento estático y coherente dentro del mismo segmento de red (192.168.10.x), permitiendo que ambos sistemas se reconozcan mutuamente y se comuniquen de forma directa y aislada para llevar a cabo la simulación del ataque sin interferencias externas.



Desarrollo de portal web

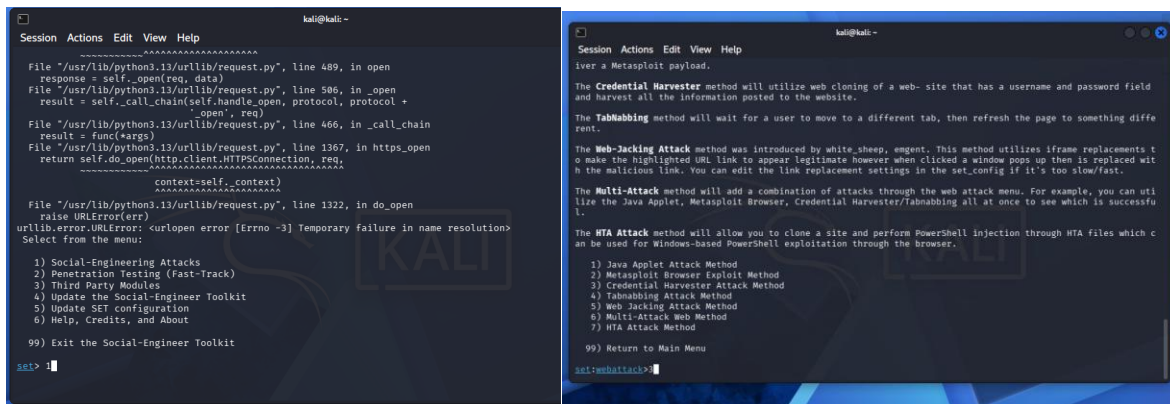
En el editor de texto de Kali Linux se edita y personaliza el archivo `index.html` para estructurar un portal web de inicio de sesión falso. Como se observa en la vista previa del navegador, el resultado es una interfaz limpia y profesional que incluye un logotipo corporativo ("AETHEL INNOVATIONS"), un mensaje de ingeniería social con apariencia legítima ("Your session has expired. Please log in again to continue.") y campos específicos para la captura de credenciales ("Mail" y "Password"), los cuales quedan listos para ser desplegados a través del servidor web de pruebas.



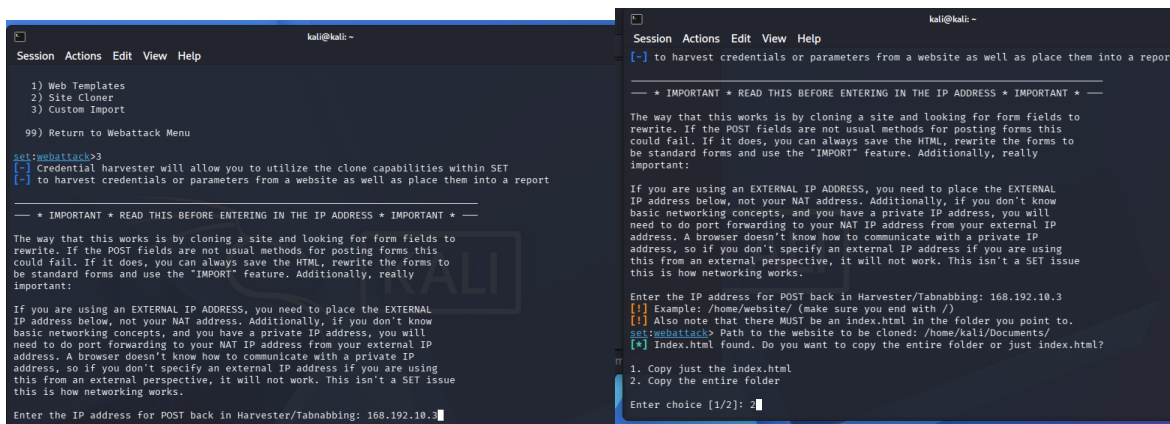
Configuración de SET

En la terminal de Kali Linux se ejecuta el comando “`sudo setoolkit`” para iniciar el Social-Engineer Toolkit, mostrando inicialmente un aviso de error de resolución temporal debido a que se encuentra en un entorno aislado sin conexión a internet, pero desplegando correctamente el menú principal de la herramienta donde se selecciona la opción "1" (Social-Engineering Attacks) y posteriormente la opción "2" (Website Attack Vectors) para configurar las opciones de ataque web.

En la última pantalla del menú de ataques web, se visualizan las descripciones de los diferentes métodos disponibles y se selecciona la opción "3" (Credential Harvester Attack Method), la cual se utiliza para poner en marcha el servidor de recolección y utilizar plantillas o archivos HTML personalizados que permitan capturar las credenciales ingresadas por los usuarios en la red interna.



Dentro del módulo del *Credential Harvester* en SET, tras seleccionar la opción de importación personalizada, se introduce la dirección IP del servidor atacante (192.168.10.3) para configurar el retorno de las peticiones POST, estableciendo a continuación la ruta absoluta del directorio de documentos (/home/kali/Documents/) donde se encuentra alojado el archivo index.html. Al detectar correctamente el archivo principal, la herramienta solicita especificar si se desea copiar únicamente el archivo o la carpeta completa, introduciendo la opción "2" para copiar el directorio entero, lo que permite integrar todos los recursos visuales e imágenes de la plantilla web personalizada.



```
Session Actions Edit View Help
1) Web Templates
2) Site Cloner
3) Custom Import
99) Return to Webattack Menu

set:webattack>
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report

--- * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * ---

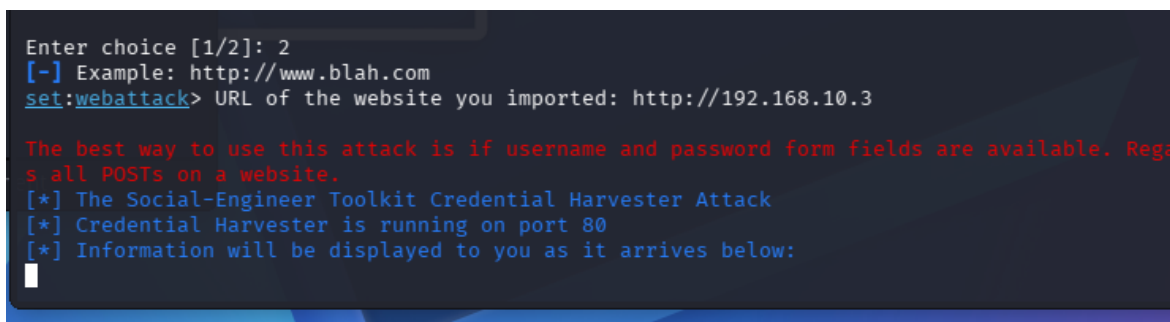
The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

Enter the IP address for POST back in Harvester/Tabnabbing: 168.192.10.3
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/kali/Documents/
[*] Index.html found. Do you want to copy the entire folder or just index.html?

1. Copy just the index.html
2. Copy the entire folder
Enter choice [1/2]: 2
```

Finalmente, se completa la configuración indicando la URL del sitio importado (http://192.168.10.3), lo que provoca que el módulo inicie oficialmente el servicio del *Credential Harvester* ejecutándose en el puerto 80, quedando a la espera y lista para mostrar en tiempo real la información que sea interceptada desde la red interna.



```
Enter choice [1/2]: 2
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported: http://192.168.10.3

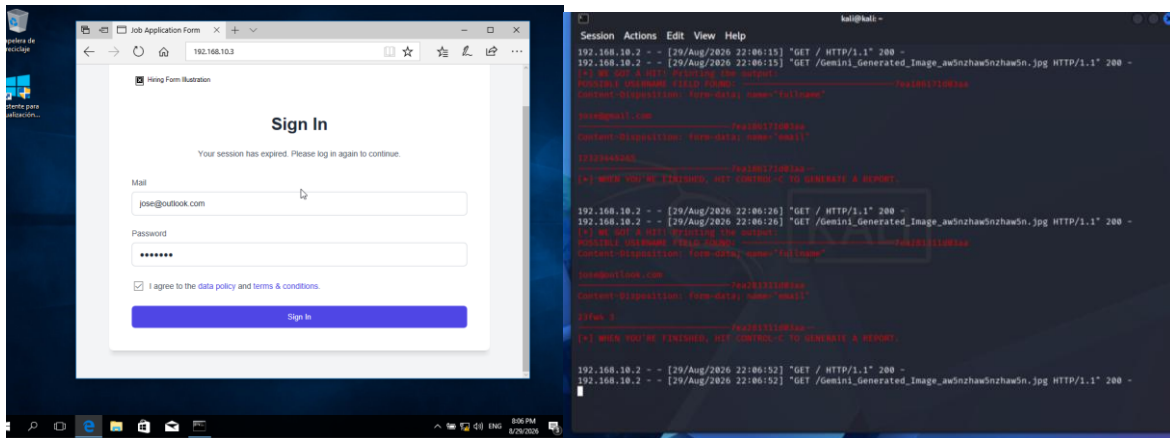
The best way to use this attack is if username and password form fields are available. Rega
s all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
█
```

Intercepción de la información

Desde el navegador web de la máquina virtual con Windows 10, al acceder a la dirección IP del servidor atacante (192.168.10.3), se visualiza el formulario de inicio de sesión falso donde se ingresan datos de prueba en los campos correspondientes —introduciendo un correo en el apartado de usuario y una contraseña simulada—, completando el proceso al aceptar los términos y dar clic en el botón de envío.

En la terminal de Kali Linux se comprueba el éxito de la simulación al mostrarse la alerta [+]
WE GOT A HIT!, la cual imprime de manera inmediata y en texto plano la información capturada de las solicitudes HTTP POST enviadas desde la máquina víctima (192.168.10.2), mostrando

detalladamente los campos y valores ingresados (como las credenciales de correo y contraseña) que sirven como evidencia final de la recolección en el laboratorio.



Explicación del flujo de captura de información.

El flujo de captura de información en un ataque de *Credential Harvesting* describe la ruta técnica y lógica que siguen los datos desde el equipo de la víctima hasta el sistema atacante. Este proceso se desarrolló en las siguientes etapas:

1. **Solicitud y renderizado del portal malicioso (GET):** Cuando la máquina víctima (Windows 10, IP 192.168.10.2) accede mediante el navegador a la dirección IP del servidor atacante (192.168.10.3 en el puerto 80), se envía una petición HTTP GET. El servidor de Kali Linux responde entregando la estructura del sitio web falso previamente configurado (index.html), permitiendo que el cliente renderice visualmente la interfaz simulada (con el formulario de inicio de sesión y los avisos de sesión expirada).
2. **Interacción del usuario y llenado del formulario:** El usuario ingresa sus datos sensibles (en este caso, una cuenta de correo electrónico y una contraseña de prueba) en los campos correspondientes del formulario y acciona el botón de envío (*Sign In*). En este punto, la lógica del formulario web procesa los datos introducidos para empaquetarlos y transmitirlos.
3. **Transmisión de credenciales mediante petición HTTP POST:** En lugar de enviar la información a un servidor legítimo, el navegador de la víctima dirige la solicitud utilizando el método **HTTP POST** directamente hacia la dirección IP del servidor controlado por el atacante. Debido a que el laboratorio opera en una red interna simulada sin certificados de seguridad válidos (HTTP en lugar de HTTPS), la transmisión de estos datos se realiza completamente en texto plano.
4. **Intercepción y registro de la información (*Credential Harvesting*):** El módulo *Credential Harvester* de SET, ejecutándose en el puerto 80 de la máquina Kali Linux, intercepta las cabeceras y los parámetros de la petición HTTP POST entrante. La herramienta procesa automáticamente la solicitud, extrae los valores asociados a los campos de entrada de usuario y contraseña, y emite una alerta visual en la terminal ([+] WE GOT A HIT!).

5. **Extracción y visualización de evidencias:** Finalmente, la terminal del sistema atacante imprime de manera estructurada y en texto plano los parámetros capturados (como fullname, email y las credenciales introducidas), proporcionando al operador los registros necesarios para documentar el éxito de la prueba de concepto y analizar las debilidades explotadas.

Controles de seguridad propuestos.

Indicadores de Phishing

- **Urgencia o presión psicológica:** En la interfaz del portal simulado se incorporó un mensaje explícito que indicaba que la sesión había expirado. Este tipo de táctica busca manipular emocionalmente al usuario, generando un falso sentido de urgencia o temor a perder el acceso a sus herramientas de trabajo, lo que le induce a actuar de forma impulsiva y sin verificar la autenticidad del sitio.
- **Dominio o URL sospechosa / Uso de IP directa:** Al realizar la prueba de acceso desde la máquina víctima, el navegador no apuntaba a un dominio corporativo legítimo validado por el sistema de nombres de dominio (DNS), sino directamente a una dirección IP numérica en formato de red local (http://192.168.10.3). En escenarios reales, los atacantes suelen utilizar subdominios extraños, faltas ortográficas deliberadas en el nombre de la marca o dominios de aspecto sospechoso.
- **Ausencia de certificado SSL válido:** El servidor web desplegado operaba sobre el puerto 80 utilizando el protocolo HTTP estándar sin cifrado. Esto se traduce en la ausencia del icono de candado en la barra de direcciones del navegador y en la falta de certificados SSL/TLS válidos. Un sitio web corporativo legítimo siempre cifra sus comunicaciones de extremo a extremo y exige HTTPS de manera estricta.
- **Apariencia visual imitando a un servicio o marca:** El diseño del formulario se estructuró deliberadamente para generar una falsa confianza en la víctima. Para ello, se integraron elementos visuales estéticos, un logotipo representativo simulado y una distribución idéntica a la de un portal de autenticación convencional (campos de correo y contraseña, acompañados de un botón de inicio de sesión estilizado).
- **Solicitud de información sensible directa:** El formulario solicita credenciales críticas de manera directa e inusual. En portales legítimos modernos, los procesos de autenticación suelen estar desacoplados (por ejemplo, pidiendo primero el correo, validando la existencia de la cuenta y solicitando factores adicionales antes de permitir el ingreso de la contraseña).

Propuesta de controles de seguridad

Autenticación Multifactor (MFA / 2FA):

- **Alcance:** Exige al usuario la verificación mediante un segundo factor independiente de la contraseña. Su principal logro es que, aunque el atacante logre cosechar la contraseña en texto plano mediante una página de phishing, el acceso a la plataforma le será denegado al carecer del token secundario.

- **Limitación:** No previene de manera absoluta ataques avanzados de tipo *Adversary-in-the-Middle* (AiTM) en tiempo real, donde herramientas maliciosas intermedias interceptan tanto la credencial como el código de sesión válido de forma simultánea.

Capacitación y Concientización en Ciberseguridad (Phishing Awareness):

- **Alcance:** Educa de forma continua al usuario final para que desarrolle un pensamiento crítico y aprenda a reconocer las señales de alerta antes mencionadas antes de interactuar con correos o portales sospechosos.
- **Limitación:** El factor humano es inherentemente variable y difícil de controlar al 100%. Un empleado bajo altos niveles de estrés o distracción puede pasar por alto los indicadores de riesgo y caer en campañas de ingeniería social altamente sofisticadas.

Uso de Listas de Bloqueo y Filtros de Correo (Antiphishing Gateways):

- **Alcance:** Automatiza la detección y el bloqueo de correos electrónicos maliciosos, adjuntos peligrosos y dominios reportados como fraudulentos directamente en la pasarela de correo, evitando que la amenaza siquiera llegue a la bandeja de entrada del usuario.
- **Limitación:** Su efectividad disminuye drásticamente ante dominios de phishing "de un solo uso" o infraestructura de ataque recién creada que aún no cuenta con reportes previos en las bases de datos globales de reputación.

Políticas de Acceso Condicional y Dispositivos Gestionados:

- **Alcance:** Restringe el acceso a los recursos y sistemas corporativos exclusivamente a aquellos dispositivos que estén inventariados, cifrados, cumplan con las normativas de seguridad de la empresa y provengan de ubicaciones o redes de confianza.
- **Limitación:** Puede generar fricción operativa, resistencia por parte del personal o afectar la movilidad del usuario si las políticas son demasiado restrictivas y no se calibran de acuerdo con las necesidades del negocio.

Gestión de Identidades y Monitoreo de Credenciales Comprometidas:

- **Alcance:** Realiza análisis automatizados en bases de datos públicas de filtraciones para detectar de manera temprana si las credenciales de un usuario han sido expuestas, permitiendo forzar un reinicio de contraseña inmediato antes de que sean utilizadas por terceros.
- **Limitación:** Es estrictamente una medida de mitigación y contención posterior al incidente. Actúa cuando el engaño ya ocurrió y la información ya fue vulnerada, limitando el daño pero sin evitar la fase inicial del ataque.

Conclusión.

La realización de esta práctica de laboratorio permitió comprender de manera práctica y controlada la anatomía y el impacto de un ataque de *Credential Harvesting* mediante el uso de herramientas de ingeniería social como el Social-Engineer Toolkit (SET) y la estructuración de portales web simulados. A través del aislamiento de la red y el uso de direccionamiento estático en un entorno virtualizado, se demostró cómo la falta de cifrado (HTTP en lugar de HTTPS) y la ausencia de validación de dominios legítimos facilitan la interceptación de información confidencial en texto plano.

Asimismo, el ejercicio deja ver que el factor humano sigue siendo uno de los vectores más vulnerables ante técnicas de manipulación psicológica, como la simulación de alertas de sesión expirada. Esto resalta la necesidad crítica de no depender exclusivamente de la seguridad perimetral, sino de adoptar una estrategia de defensa en profundidad que combine controles preventivos y detectivos indispensables —tales como la Autenticación Multifactor (MFA), el uso obligatorio de certificados SSL/TLS y la capacitación continua del personal— para mitigar eficazmente el riesgo de suplantación de identidad y proteger los activos informáticos de las organizaciones.

Referencias.

Kennedy, D. (2014). *The Social-Engineer Toolkit (SET) user manual*. TrustedSec.
https://github.com/trustedsec/social-engineer-toolkit/blob/master/readme/User_Manual.pdf

Patrick Hernandez. (2024, 21 noviembre). *Probando un ataque Phishing con SEToolkit en Kali Linux* [Vídeo]. YouTube. <https://www.youtube.com/watch?v=uL8DmOpkxtA>